Experiment-18

18. Vulnerabilities Analysis Using CGI Scanning with Nikto

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://saveetha.com
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          3.110.122.44
+ Target Hostname:    saveetha.com
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-10-27 00:49:41 (GMT-4)
---------------------------------------------------------------------------
+ Server: Squarespace
+ Multiple IPs found: 3.110.122.44, 198.185.159.144, 198.185.159.145
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'x-contextid' found, with contents: n5t119Ra/Y3b5jEHS.
+ [95] /: Cookie crumb created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [999100] /cgi.cgi/: Uncommon header(s) 'x-sqsp-edge' found, with contents: true.
+ [999962] /: Server banner changed from 'Squarespace' to 'nginx/1.24.0 (Ubuntu)'.
+ [999100] /VsN8wMe0/: Uncommon header(s) 'refresh' found, with contents: 0;url=/VsN8wMe0.
+ [999100] /robots.txt: Uncommon header(s) 'x-nextjs-cache' found, with contents: HIT.
+ [999986] /WRyjadIL.txt: Retrieved x-powered-by header: Next.js.
+ [999100] /WRyjadIL.txt: Uncommon header(s) 'x-nextjs-stale-time' found, with contents: 300.
+ [999100] /WRyjadIL.txt: Uncommon header(s) 'x-nextjs-prerender' found, with contents: 1,1.
+ [999996] /robots.txt: contains 11 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
-        - STATUS: Completed 720 requests (~10% complete, ~25.5 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.18360 sec, 10 requests: 0.1857 sec.
- STATUS: Completed 730 requests (~10% complete, ~25.4 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.18431 sec, 10 requests: 0.1833 sec.

  - STATUS: Completed 1230 requests (~17% complete, ~26.7 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.26375 sec, 10 requests: 0.2509 sec.
    - STATUS: Completed 1240 requests (~17% complete, ~26.6 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.24396 sec, 10 requests: 0.2442 sec.
- STATUS: Completed 1250 requests (~17% complete, ~26.5 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.23979 sec, 10 requests: 0.2458 sec.
- STATUS: Completed 1260 requests (~17% complete, ~26.4 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.23965 sec, 10 requests: 0.2433 sec.
- STATUS: Completed 1270 requests (~18% complete, ~26.3 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.24121 sec, 10 requests: 0.2453 sec.
- STATUS: Completed 1280 requests (~18% complete, ~26.2 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.23804 sec, 10 requests: 0.2410 sec.
    - STATUS: Completed 1340 requests (~19% complete, ~26.0 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.24604 sec, 10 requests: 0.2495 sec.
- STATUS: Completed 1350 requests (~19% complete, ~26.1 minutes left): currently in plugin 'Nikto Tests'
```

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://saveetha.com -p
Option port requires an argument

   Options:
       -Add-header         Add HTTP headers (can be used multiple times, one per header pair)
       -ask+               Whether to ask about submitting updates
                               yes   Ask about each (default)
                               no    Don't ask, don't send
                               auto  Don't ask, just send
       -check6             Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
       -Cgidirs+           Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
       -config+            Use this config file
       -Display+           Turn on/off display outputs:
                               1     Show redirects
                               2     Show cookies received
                               3     Show all 200/OK responses
                               4     Show URLs which require authentication
                               D     Debug output
                               E     Display all HTTP errors
                               P     Print progress to STDOUT
                               S     Scrub output of IPs and hostnames
                               V     Verbose output
       -dbcheck            Check database and other key files for syntax errors
       -evasion+           Encoding technique:
                               1     Random URI encoding (non-UTF8)
                               2     Directory self-reference (/./)
                               3     Premature URL ending
                               4     Prepend long random string
                               5     Fake parameter
                               6     TAB as request spacer
                               7     Change the case of the URL
                               8     Use Windows directory separator (\)
                               A     Use a carriage return (0x0d) as a request spacer
                               B     Use binary value 0x0b as a request spacer
       -followredirects    Follow 3xx redirects to new location
       -Format+            Save file (-o) format:
                               csv   Comma-separated-value
                               json  JSON Format
                               htm   HTML Format
                               sql   Generic SQL (see docs for schema)
                               txt   Plain text
                               xml   XML Format
```

```
       -nohookup          Disables DNS lookups
       -nossl             Disables the use of SSL
       -noslash           Strip trailing slash from URL (e.g., '/admin/' to '/admin')
       -no404             Disables nikto attempting to guess a 404 page
       -Option            Over-ride an option in nikto.conf, can be issued multiple times
       -output+           Write output to this file ('.' for auto-name)
       -Pause+            Pause between tests (seconds)
       -Platform+         Platform of target (nix, win, all)
       -Plugins+          List of plugins to run (default: ALL)
       -port+             Port to use (default 80)
       -RSAcert+          Client certificate file
       -root+             Prepend root value to all requests, format is /directory
       -Save              Save positive responses to this directory ('.' for auto-name)
       -ssl               Force ssl mode on port
       -Tuning+           Scan tuning:
                              1     Interesting File / Seen in logs
                              2     Misconfiguration / Default File
                              3     Information Disclosure
                              4     Injection (XSS/Script/HTML)
                              5     Remote File Retrieval - Inside Web Root
                              6     Denial of Service
                              7     Remote File Retrieval - Server Wide
                              8     Command Execution / Remote Shell
                              9     SQL Injection
                              0     File Upload
                              a     Authentication Bypass
                              b     Software Identification
                              c     Remote Source Inclusion
                              d     WebService
                              e     Administrative Console
                              x     Reverse Tuning Options (i.e., include all except specified)
       -timeout+          Timeout for requests (default 10 seconds)
       -Userdbs           Load only user databases, not the standard databases
                              all   Disable standard dbs and load only user dbs
                              tests Disable only db_tests and load udb_tests
       -useragent         Force User-Agent instead of pulling from database
       -url+              Target host/URL (alias of -host)
       -useproxy          Use the proxy defined in nikto.conf, or argument http://server:port
       -Version           Print plugin and database versions
       -vhost+            Virtual host (for Host header)
       -404code           Ignore these HTTP codes as negative responses (always). Format is "302,301".
       -404string         Ignore this string in response body content as negative response (always). Can be a regular expression.
                + requires a value
```

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://saveetha.com -ssl
- Nikto v2.6.0
---------------------------------------------------------------------------
+ [FAIL] Unable to connect to saveetha.com:80.

┌──(kali㉿kali)-[~]
└─$ nikto -h http://saveetha.com -host www.test.com
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          104.18.16.52
+ Target Hostname:    www.test.com
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-10-27 01:02:51 (GMT-4)
---------------------------------------------------------------------------
+ Server: cloudflare
+ Multiple IPs found: 104.18.16.52, 104.18.17.52, 2606:4700:9763:fe64:7cfd:249:68c6:3825
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'speculation-rules' found, with contents: "/cdn-cgi/speculation".
+ [011799] /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
+ [999106] /: Cloudflare detected via cf-ray header. Recommend proxying via Burp or mitmproxy to avoid TLS fingerprint blocks. See: https://github.com/sullo/nikto/wiki/Using-a-Proxy
+ [999100] /cgi-exe/: Uncommon header(s) 'reporting-endpoints' found, with contents: cf-csp-endpoint="https://csp-reporting.cloudflare.com/cdn-cgi/script_monitor/report?m=EbJxB3xsK84q1MYOQcuiwmGGE3vBOxqdm7
0.1.1-MJBlEbVga3WVk6zzBs9tP6WrbWodnRug.qBVGYDYfospf0tz_G8m08xHZqebmBUUBLweD0gT_ErmvZp7d.4FHySd5yCiZfxW80YcyNd9037bovvt8wu4ZnWzU39nyd4_I_61pLVnuLIVhhkgrAFZk9zUxrJuchYeVsmIUohOg4M".
+ No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.
```